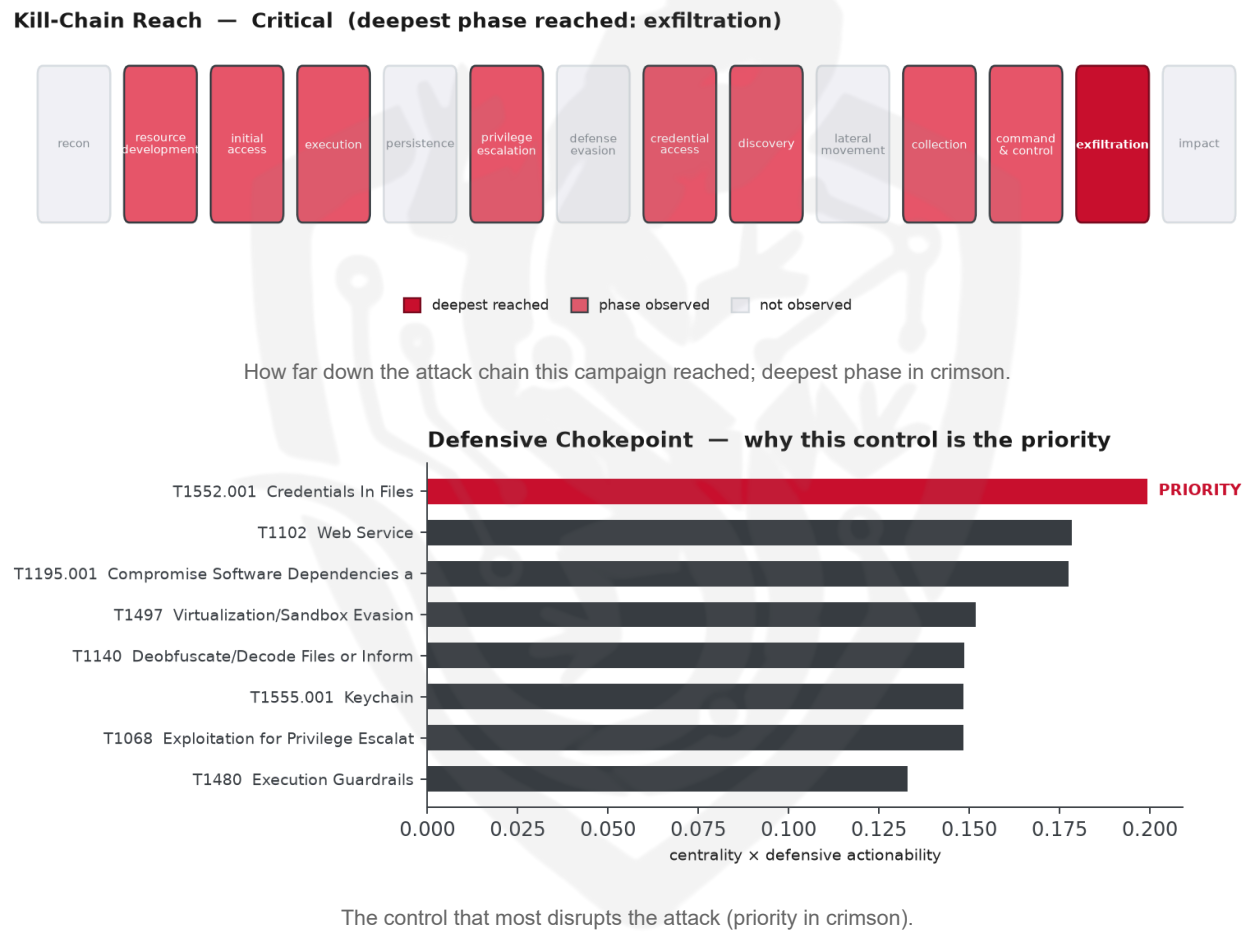


THREAT REPORT: MALICIOUS PACKAGIST THEMES DELIVER IOS SPYWARE STEALING CRYPTO WALLET SEEDS

Visual Summary



Summary

A cluster of activity is distributing malicious Packagist themes that install iOS spyware capable of extracting cryptocurrency wallet seeds. The campaign leverages CVE-2025-43529 to gain execution on vulnerable systems. While the specific victims are not enumerated, the payload targets iOS users who manage crypto wallets. Priority should be given to removing secrets from code, configuration files, and registries, deploying a secrets manager, scanning repositories and hosts for credentials, and patching CVE-2025-43529 on all affected devices.

Threat Overview

The observed cluster delivers iOS spyware through compromised Packagist themes; no malware family has been identified. Exploitation centers on the vulnerability CVE-2025-43529. The primary victims are iOS users, particularly those holding cryptocurrency wallet credentials.

Attack Chain and Priority Control

The attackers first compromise software dependencies (T1195.001) by injecting malicious Packagist themes, then achieve client execution via exploitation for client execution (T1203) and privilege escalation (T1068). The payload performs screen capture (T1113), automated collection (T1119), and extracts credentials from files (T1552.001) and keychain data (T1555.001). Collected data is encoded (T1132.001), exfiltrated over web services (T1102) and C2 channels (T1041), and the malware is uploaded to victims (T1608.001). The chokepoint technique is **T1552.001 Credentials In Files**, and the concrete control is: **Remove secrets from code/config/registry; deploy a secrets manager; scan repos and hosts for credentials. In parallel, patch CVE-2025-43529 on all affected systems.**

Infrastructure and Corroboration

The malicious infrastructure is hosted by CNServers LLC, as observed in the associated ASN data. No malware families have been corroborated by abuse.ch, and AbuseIPDB does not flag any related indicators with high confidence.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1113 Screen Capture
- T1132.001 Standard Encoding
- T1539 Steal Web Session Cookie
- T1195.001 Compromise Software Dependencies and Development Tools
- T1555.001 Keychain
- T1119 Automated Collection
- T1608.004 Drive-by Target
- T1005 Data from Local System
- T1140 Deobfuscate/Decode Files or Information
- T1608.001 Upload Malware
- T1497 Virtualization/Sandbox Evasion
- T1102 Web Service
- T1552.001 Credentials In Files
- T1480 Execution Guardrails
- T1041 Exfiltration Over C2 Channel
- T1068 Exploitation for Privilege Escalation
- T1027 Obfuscated Files or Information

- T1203 Exploitation for Client Execution
- T1189 Drive-by Compromise
- T1071.001 Web Protocols

Analytical Scores

- Priority technique (graph chokepoint): T1552.001 Credentials In Files (centrality 0.3105).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3153; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
OilRig	0.3153
Threat Group-3390	0.3073
APT42	0.2917
APT33	0.2917
BRONZE BUTLER	0.2889

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	23[.]225[.]48[.]20	AbuseIPDB 0% (US) · AS40065 CNSe rvers LLC
IP	23[.]225[.]52[.]67	AbuseIPDB 0% (US) · AS40065 CNSe rvers LLC
Domain	xemphimlau[.]com	

Type	Indicator	Context
Domain	funnull01[.]vip	
Domain	cre-ads[.]com	
Domain	im[.]ue8im[.]com	
Domain	cdn[.]data-2920[.]com	
Domain	www[.]cloudfareintcdn[.]com	
Domain	galedns[.]com	
Domain	xl0ph4qz[.]vip	
Domain	cloudfareintcdn[.]com	
Domain	dq87771[.]com	
Domain	ismzt[.]cc	
Domain	cdn[.]data-2919[.]com	
URL	hxxp://23[.]225[.]52[.]67:4466/vip344[.]html	
URL	hxxp://23[.]225[.]48[.]20:4466/vip/index[.]php	
URL	hxxp://cdn[.]data-2920[.]com/app[.]vue[.]js	
URL	hxxp://cloudfareintcdn[.]com/wd-status[.]html	
URL	hxxp://union[.]macoms[.]la/jquery[.]min-3[.]6[.]8[.]js	
URL	hxxp://www[.]cloudfareintcdn[.]com/in-static[.]js	
URL	hxxp://xl0ph4qz[.]vip:7740	
URL	hxxps://im[.]ue8im[.]com/wg-2023440066/640-100-1[.]gif	

Type	Indicator	Context
Hash	60b6771958cb7e553994ba6752f108575ba70e02d24affb51d8936a17eb0bf5e	
Hash	d9530e8cd79ac7b3d02b04e05426653afca7075fcf7424eec4d59c6e95745933	
Hash	92c7d246d2c163c076f783dcc19f87f5b9b9ac301b106b87a7a aea9346ce0052	
Hash	f2fdfdbbc436acc24a654092f5205b2c5bd3208b126b2c2754ac 63e7aea22298	
Hash	9d6b58886189c0e23f706c32d3d8dda97b0b6d927ece6de072 70813f070295b5	
Hash	de539a63cbe27bbd4a7db30fc796cd6dc5309c02ef5e60a3c5cf 0835e5601283	
Hash	22c75b2ee026dbbf7001cfdc2bb47855	
Hash	b216e777ad85e77b033d68ad429d869a	
Hash	ac97f82098288232e8c6e0c8ce5f196b92b3bf59	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1552.001 Credentials In Files (credential-access)
- **Observed here:** T1552.001 Credentials In Files was the only credential-access technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1003 OS Credential Dumping (credential-access)
- **Basis:** of the 18+ groups that use Credentials In Files, this pairing runs 2.5x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1552.001 Credentials In Files blocked, the threat actor could preserve the same objective by pivoting to T1003 OS Credential Dumping, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Protect LSASS (RunAsPPL, Credential Guard); alert on LSASS handle access; disable WDigest.

Also plausible (same tactic): T1556 Modify Authentication Process (n=4, lift 4.0), T1110 Brute Force (n=8, lift 2.6)

Detection and hardening for the pivot (T1003 OS Credential Dumping)

- **Telemetry:** Sysmon (process access); EDR credential-theft telemetry
- **Detect:**
 - Sysmon 10 (process access) targeting lsass.exe with suspicious access masks
 - Access to ntds.dit / SAM / SYSTEM hives; vssadmin/shadow-copy abuse
 - comsvcs.dll MiniDump, procdump, or reg save of security hives
- **Harden:**
 - Enable Credential Guard and LSA protection (RunAsPPL)
 - Restrict debug privilege; tiered admin to limit credential exposure
- **MITRE:** M1043 Credential Access Protection, M1028 Operating System Configuration, M1026 Privileged Account Management, M1017 User Training · DS0009 Process, DS0022 File, DS0024 Windows Registry

